

Critical Reproduction of an Autoencoder-Based Network Intrusion Detection System on CIC-IDS2017

Final Project — Data Science in Cybersecurity

Dr. Uri Itai, University of Haifa

Source under review: brett-gt, Intrusion Detection System (GitHub)

Author: Adi Bishara

Contents

CONTENTS	1
1. SUMMARY OF THE SOURCE	2
2. CRITICAL EVALUATION.....	3
3. FEATURE ENGINEERING ANALYSIS	5
4. REPRODUCIBILITY ANALYSIS	7
5. EXPERIMENTAL RESULTS.....	8
5.1 CLASS BALANCE AND EXPLORATORY ANALYSIS.....	8
5.2 EVALUATION METRICS.....	9
5.3 RESULTS	10
5.4 ERROR ANALYSIS	13
6. CONCLUSIONS	13
7. EXECUTIVE SUMMARY.....	14
8. SUMMING IT UP	15

1. Summary of the Source

Source under review: the GitHub project Intrusion Detection System by the user brett-gt — an autoencoder-based network intrusion detector trained and evaluated on the CIC-IDS2017 dataset (<https://github.com/brett-gt/IntrusionDetectionSystem>).

The problem being addressed. The project tackles network intrusion detection: distinguishing malicious traffic (DoS/DDoS, port scans, brute-force, web attacks, infiltration, botnet) from benign traffic in a large flow-level dataset. Rather than framing this as supervised classification, the author adopts an anomaly-detection formulation — model what normal traffic looks like, and flag whatever deviates from it.

Why the problem is important. In a realistic deployment, labelled attack data is scarce, attacks are rare relative to benign traffic, and novel (zero-day) attacks have no signatures. An anomaly-detection approach that learns only from benign traffic is attractive precisely because it requires no labelled attacks and can, in principle, flag previously unseen attack types. This makes the autoencoder framing well-motivated for operational intrusion detection.

The proposed solution. The author trains a two-layer sparse autoencoder with L1 kernel regularisation on the hidden layer, exclusively on Monday's benign traffic, to learn the identity function for normal flows. At test time, a flow's mean reconstruction error is its anomaly score: benign flows reconstruct well (low error), attacks reconstruct poorly (high error). A decision threshold separates the two classes.

The dataset used. CIC-IDS2017 (Canadian Institute for Cybersecurity), comprising five days of network traffic with roughly 2.8 million labelled flows and 83 statistical flow features (packet counts, byte counts, inter-arrival times, and their min/max/mean/standard-deviation aggregates). Monday is entirely benign; Tuesday–Friday interleave benign traffic with specific attack campaigns.

The model and methodology. Preprocessing applies min–max normalisation to numerical features, removes erroneous rows (infinities, NaNs), one-hot encodes source/destination IPs into three address classes and the transport protocol, and min–max-normalises the destination port. Feature selection is a manually chosen subset of the 83 features. The anomaly threshold is selected by empirically searching candidate thresholds for the one that maximises the count of correctly classified attacks and benign flows. The reported headline results are 91.3% of benign traffic correctly passed (8.7% false-positive rate) and 98.3% of attacks detected (1.7% false-negative rate), with very strong detection of volumetric attacks (DDoS, PortScan, DoS Hulk) and much weaker detection of low-volume attacks (e.g. Bot: 289 detected vs 1,677 missed).

2. Critical Evaluation

This section assesses whether the author's headline claims — 98.3% attack detection at an 8.7% false-positive rate — are supported by the evidence, and whether the evaluation methodology is appropriate for the stated problem. We reproduce the approach (a benign-only autoencoder on CIC-IDS2017) and find that, while the autoencoder genuinely carries discriminative signal, three methodological choices cause the reported figures to overstate real-world performance.

Main claims made by the author. (1) The autoencoder detects 98.3% of attacks at an 8.7% false-positive rate. (2) Reconstruction error is an effective anomaly score across diverse attack types. (3) Training on benign-only data is sufficient to build an effective detector.

Claim 1 is not supported as a measure of deployable performance — it rests on a leaky evaluation. Two issues compound:

Duplicate-driven leakage. CIC-IDS2017 contains a large fraction of exact-duplicate flow records. In our analysis, 22.8% of all rows are exact duplicates (2,830,743 rows reduce to 2,185,714 unique), and duplication is concentrated in the attack class — de-duplication removed 39.7% of attack rows (557,646 → 336,030) versus 18.6% of benign rows (2,273,097 → 1,849,684). The source applies no de-duplication; its evaluation counts 2,273,097 benign flows, which exactly equals the full duplicate-inclusive benign population. Because duplicated flows appear in both the data the model is fitted/tuned on and the data it is evaluated on, the reported true-positive and true-negative rates are optimistic. When we remove duplicates before splitting, we obtain a leakage-free estimate.

Threshold tuned on the evaluation set. The author selects the decision threshold as the one that provides the maximum true-positive and true-negative counts — i.e. the threshold is optimised on the same data used to report performance. This is a form of evaluation-set leakage. In our pipeline we select the threshold on a validation split and report on a disjoint test split, yielding a more honest operating point.

The evaluation methodology is inappropriate because it ignores class prevalence. The 8.7% false-positive rate sounds small, but intrusion detection is an extreme class-imbalance problem: in deployment, attacks are rare. Reporting only TPR and FPR — both prevalence-independent — hides the precision a deployed operator would actually experience. Using our detector's measured recall (0.736) and FPR (0.040), projected precision falls to approximately 16% at 1% attack prevalence, 1.8% at 0.1%, and 0.18% at 0.01%. At realistic attack rates the overwhelming majority of alerts are false, regardless of the headline 8.7% FPR — a manifestation of the base-rate fallacy the source never addresses.

Additional weakness — fragile normalisation. The source applies min–max normalisation to all numerical features. Min–max scaling is highly sensitive to extreme outliers, which CIC-IDS2017 contains in abundance (e.g. Flow Bytes/s spikes); a single extreme value compresses all other values toward zero. We instead standardise (z-scoring fitted on benign-only training data), which is more robust to such tails.

Claim 2 is only partially supported. Reconstruction error works well for volumetric attacks (DDoS, PortScan, DoS Hulk), which produce flows that differ sharply from benign traffic. However, it works poorly for stealthy, low-volume attacks: the source detects only 289 of ~1,966 Bot flows and a handful of Infiltration flows. Our error analysis corroborates this — the attacks we miss (false negatives) have low reconstruction error (mean 0.091), statistically indistinguishable from benign traffic — confirming that attacks resembling normal behaviour are systematically invisible to this method.

Are the conclusions justified? Partially. The autoencoder approach is sound and carries real discriminative signal — our leakage-free reproduction achieves ROC-AUC 0.895 and MCC 0.738. But the specific quantitative claims (98.3% TPR / 8.7% FPR) overstate deployable performance because they rest on (i) un-removed duplicate leakage, (ii) a threshold tuned on the test set, and (iii) prevalence-blind metrics. The author is commendably transparent about other limitations — a single fixed random seed and an admittedly arbitrary feature subset — which further supports reading the headline numbers as an optimistic upper bound rather than an operational expectation.

Where our findings contradict the source. The source implicitly concludes the detector is near-production-ready (98.3% detection). Our evidence contradicts this: under leakage-free evaluation and prevalence-aware metrics, the same approach would, at realistic attack rates, generate overwhelmingly false alerts — making it a useful triage signal but not a standalone detector.

3. Feature Engineering Analysis

Was feature engineering performed? Yes, in both the source and our reproduction, with different choices.

The source's feature engineering. From CIC-IDS2017's 83 statistical features the author applies: min–max normalisation of numerical features; one-hot encoding of source/destination IPs into three address classes (six binary features); one-hot encoding of the transport protocol; min–max normalisation of the destination port; and manual feature selection to a subset the author describes as somewhat arbitrarily arrived at.

Our reproduction's feature engineering. We selected 20 numerical flow features (durations, packet/byte counts and lengths, inter-arrival-time statistics, header lengths, and the initial forward window size) and applied standardisation (z-scoring) fitted only on benign training data, so preprocessing leaks no information from attacks or the test set. We deliberately dropped the categorical IP-address and protocol fields, for a reason that doubles as a critique (below).

Why each transformation, and its effect. An autoencoder trained with mean-squared-error reconstruction is scale-sensitive: features with large numeric ranges (byte counts in the millions) would dominate the loss and starve small-range features of gradient. Scaling equalises feature influence. We chose standardisation over the source's min–max because CIC-IDS2017 has heavy-tailed features; min–max lets a single extreme value compress all others toward zero, whereas z-scoring is comparatively robust. Fitting the scaler on benign-only training data avoids a subtle leakage path the source does not discuss.

Is there redundancy, and how do we tackle it? Yes — CIC-IDS2017 features are highly redundant by construction. A Spearman rank-correlation analysis (chosen over Pearson because the features are non-normal and heavy-tailed) finds 16 feature pairs with $|\text{correlation}| > 0.9$. The strongest are Average Packet Size $\sim$ Packet Length Mean (+0.996), Flow Packets/s $\sim$ Flow IAT Mean (−0.996), Max Packet Length $\sim$ Packet Length Mean (+0.983), Flow Duration $\sim$ Flow Packets/s (−0.980), and Total Backward Packets $\sim$ Bwd Header Length (+0.978). These near-duplicate features would cause multicollinearity for linear models; the autoencoder's 20→4 bottleneck absorbs the redundancy by design, compressing correlated inputs into four latent factors.

Was the feature engineering meaningful — mathematically and for cybersecurity?

Mathematically, scaling is essential for a reconstruction-based model, and the bottleneck provides principled compression of redundant inputs. From a cybersecurity standpoint, the chosen flow statistics capture the dimensions along which volumetric attacks deviate (packet/byte rates and counts), which is why those attacks are detected well. The weakness is also meaningful: the feature set is purely volumetric/statistical, so attacks that mimic benign flow shapes (Bot, Infiltration) leave no signature — explaining the systematic false negatives.

Additional features that could improve performance. (i) Behavioural ratios (forward/backward packet and byte ratios) to characterise scan and exfiltration directionality; (ii) per-source temporal aggregates (distinct destinations/ports contacted within a window) — a direct signal

for port scans and lateral movement; (iii) packet-size entropy, to flag automated/botnet uniformity; (iv) inter-flow timing regularity, since C2 beaconing is periodic. These target precisely the stealthy attacks the current features miss.

4. Reproducibility Analysis

Can the code be executed? Partially. The repository provides Python source implementing the autoencoder, preprocessing, and threshold search, and fixes all random seeds to 1234, which aids determinism. However, it ships no dependency manifest, so library versions — particularly the Keras/TensorFlow version the model depends on — are unpinned and must be inferred, a common source of reproduction failure.

Are all required files and dependencies available? The code references pre-processed pickle artefacts (e.g. Monday-WorkingHours.pkl, encode_test.pkl) that are generated by the author's own preprocessing rather than provided, and the raw CIC-IDS2017 dataset must be obtained separately. Reconstructing those artefacts requires re-deriving the preprocessing exactly.

Do hidden preprocessing steps exist? Yes — the key reproducibility weakness. (i) The exact feature subset is not enumerated (selected from 83 candidates), so the precise model input cannot be reconstructed from the README. (ii) The composition of the test set is unspecified. (iii) No de-duplication step is documented, yet the benign evaluation count (2,273,097) reveals the full duplicate-laden population is used — a preprocessing decision with major impact that is never stated.

Overall reproducibility. Moderate-to-low. A practitioner can reproduce the method — a benign-only sparse autoencoder scored by reconstruction error on CIC-IDS2017 — and we did. But the specific headline figures are not independently verifiable, because the precise feature set, test-set composition, dependency versions, and de-duplication policy are underspecified. Combined with the author's acknowledgement that results may depend on the single fixed seed, this places the reported 98.3%/8.7% in the category of illustrative rather than independently reproducible results.

5. Experimental Results

Experiments performed. We reproduced the source's core approach — a benign-only autoencoder scored by reconstruction error on CIC-IDS2017 — under a corrected, leakage-free protocol, and additionally trained an Isolation Forest baseline to test whether the autoencoder's performance is method-specific or simply reflects the separability of the data.

Modifications introduced. (i) De-duplication of exact-duplicate flows before splitting; (ii) standardisation (benign-fitted z-scoring) in place of min-max; (iii) validation-based threshold selection reported on a disjoint test split; (iv) prevalence-aware evaluation; (v) a compact 20-feature numerical input with categorical IP/protocol encodings deliberately omitted.

Data partitioning. After de-duplication (2,830,743 $\rightarrow$ 2,185,714 rows), the autoencoder was trained on benign-only traffic (1,109,810 flows). Evaluation used a validation set (537,952 flows: 369,937 benign / 168,015 attack) and a disjoint test set of the same size. All randomness used a fixed seed (RANDOM_STATE = 42).

Models trained. (1) Autoencoder (primary): symmetric architecture 20 $\rightarrow$ 16 $\rightarrow$ 8 $\rightarrow$ 4 $\rightarrow$ 8 $\rightarrow$ 16 $\rightarrow$ 20, ReLU, dropout 0.2, Adam (lr 1e-3), MSE loss, 50 epochs, best checkpoint by a benign-only monitoring split. (2) Isolation Forest (baseline): 200 trees, max_samples 256, trained on the same benign-only data, threshold selected by the same max-F1-on-validation rule.

5.1 Class balance and exploratory analysis

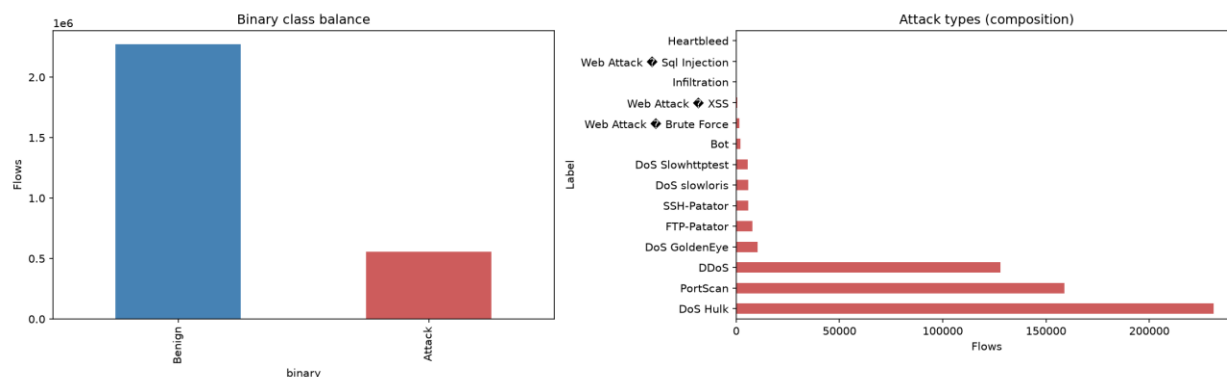


Figure 1. Binary class balance (left) and attack-type composition (right). Attacks form ~20% of the captured data — far higher than realistic deployment prevalence — and are dominated by volumetric classes.

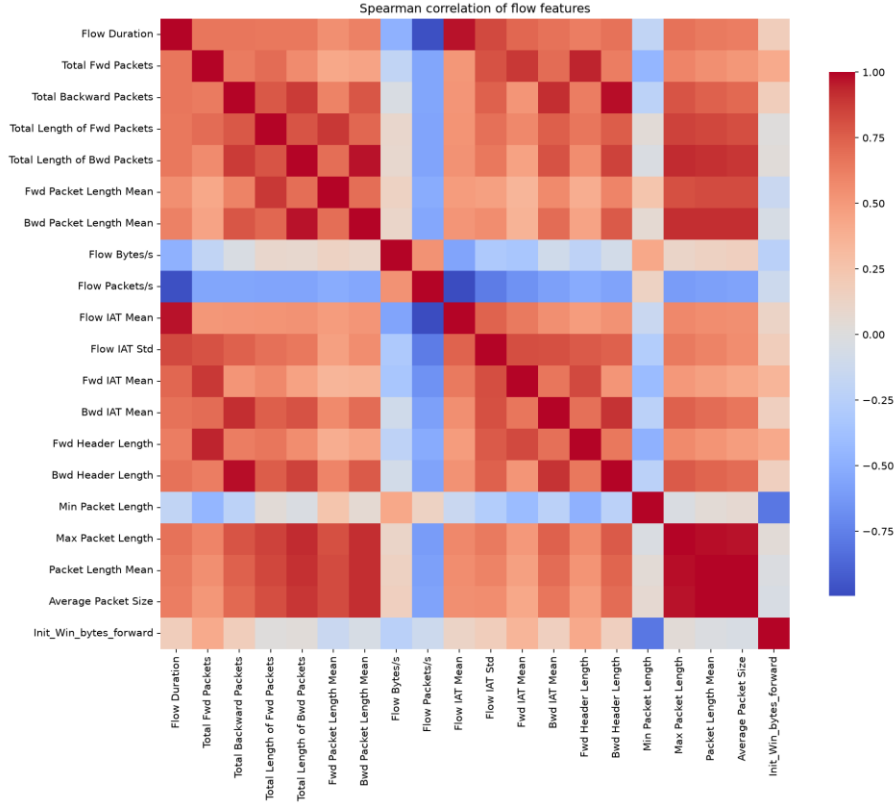


Figure 2. Spearman correlation of the 20 flow features. Strong block structure indicates substantial redundancy, compressed by the autoencoder bottleneck.

5.2 Evaluation metrics

Because intrusion detection is a rare-event, high-cost problem, we report a metric suite rather than accuracy alone. Precision is the fraction of flagged flows that are real attacks (low precision causes analyst alert-fatigue). Recall (TPR) is the fraction of attacks caught — a false negative is a missed intrusion, the most dangerous error. F1 is the harmonic mean of precision and recall; F2 weights recall twice as heavily, reflecting that a missed attack typically costs more than a false alarm. MCC is a balanced correlation reliable under class imbalance. ROC-AUC measures threshold-independent separability. Prevalence-aware precision recomputes precision at realistic attack base rates — the metric the source omits.

5.3 Results

Autoencoder (leakage-free, test set):

Metric	Value
ROC-AUC	0.895
MCC	0.738
Precision	0.894
Recall	0.736
F1	0.807
F2	0.763
Accuracy	0.890
Threshold (val-selected)	0.867
False negatives	44,351
False positives	14,697

Model comparison (test set):

Metric	Autoencoder	Isolation Forest
ROC-AUC	0.895	0.868
Precision	0.894	0.819
Recall	0.736	0.734
F1	0.807	0.774
F2	0.763	0.749
MCC	0.738	0.681
Accuracy	0.890	0.866

The autoencoder outperforms the Isolation Forest on every metric except recall (where the two are within 0.002), indicating the autoencoder captures structure in benign traffic that the tree-based isolation method does not. That both models land in a similar range confirms the result reflects genuine separability in the data rather than an artefact of one architecture.

Prevalence-aware precision (autoencoder; recall 0.736, FPR 0.040):

Attack prevalence	Projected precision
1%	0.158
0.1%	0.018
0.01%	0.0018



Figure 3. Training and benign-holdout reconstruction loss over 50 epochs.

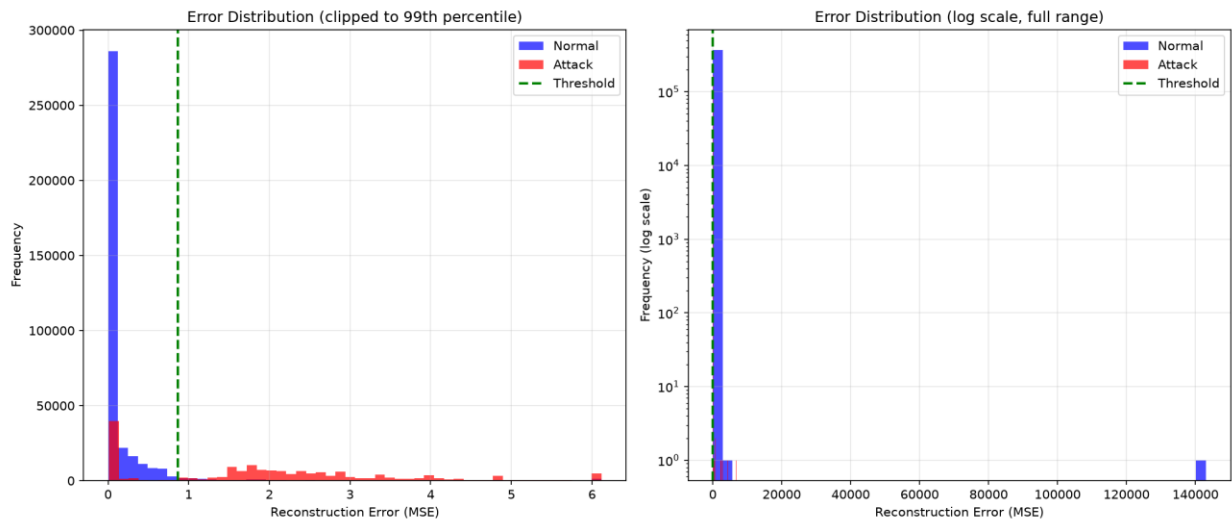


Figure 4. Reconstruction-error distributions for benign vs attack flows (left: clipped to 99th percentile; right: log scale). The threshold cleanly separates the bulk of each class, but a low-error attack tail (missed, stealthy attacks) overlaps the benign distribution.

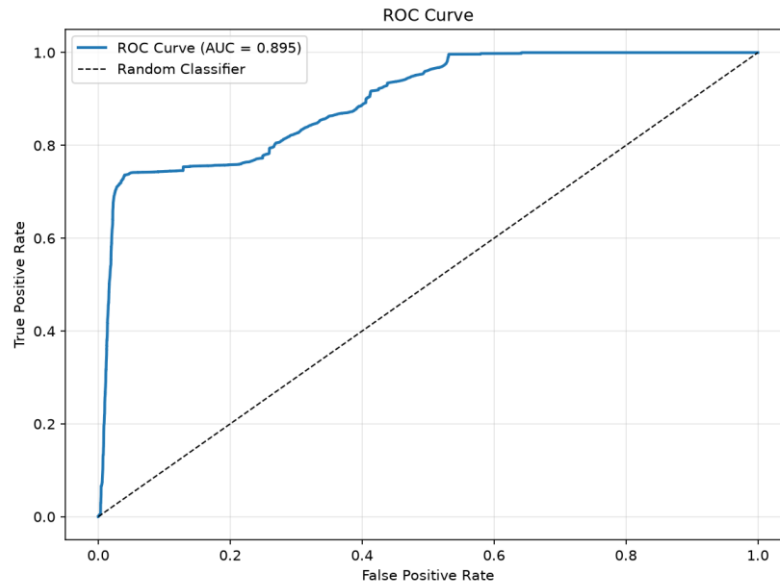


Figure 5. ROC curve for the autoencoder (AUC = 0.895).

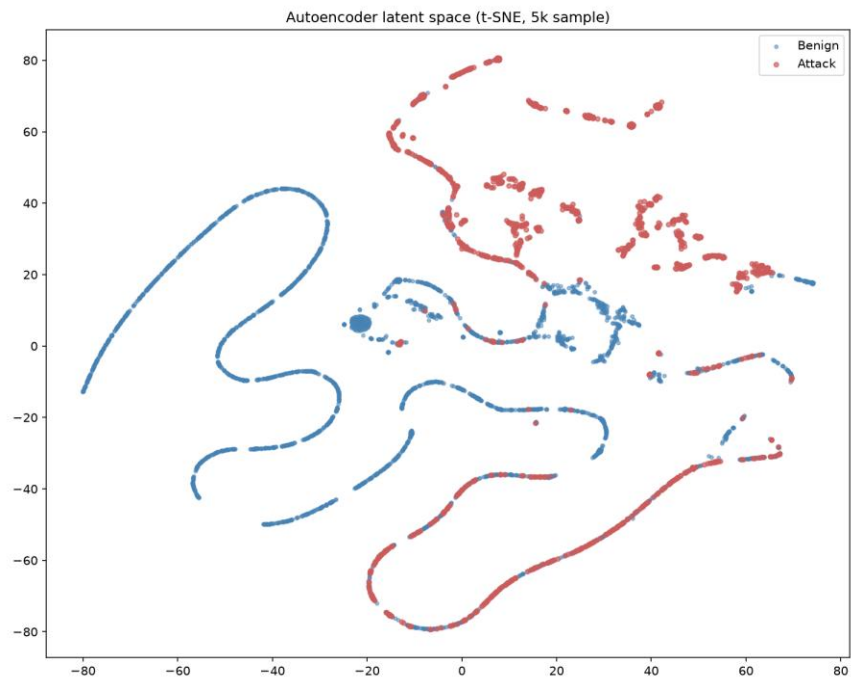


Figure 6. t-SNE projection of the 4-dimensional autoencoder latent space (5,000-flow sample): benign and attack flows occupy largely distinct regions, with overlap corresponding to the missed stealthy attacks.

5.4 Error analysis

At the selected threshold the model produces 44,351 false negatives and 14,697 false positives. The missed attacks have low reconstruction error (mean 0.091), statistically indistinguishable from benign traffic — these are the stealthy, low-volume attacks (Bot, Infiltration, some web attacks) whose flow statistics resemble normal usage. The false positives have very high error (mean ~14, with extreme outliers) — rare but legitimate heavy-traffic benign flows (large transfers) the benign-trained model has not learned to reconstruct. This asymmetry mirrors the source's own per-attack table and defines the fundamental trade-off: lowering the threshold to catch stealthy attacks would sharply increase the already-costly false-positive volume.

6. Conclusions

Key findings. (1) The autoencoder anomaly-detection approach carries genuine discriminative signal — a leakage-free reproduction reaches ROC-AUC 0.895 and MCC 0.738. (2) The source's headline figures (98.3% TPR / 8.7% FPR) overstate deployable performance due to 22.8% duplicate-driven leakage, a threshold tuned on the evaluation set, and prevalence-blind metrics. (3) Under realistic attack prevalence, precision collapses (~16% at 1%, ~2% at 0.1%). (4) Detection is concentrated in volumetric attacks; stealthy, low-volume attacks are systematically missed because they leave no signature in the volumetric feature set.

Lessons learned. Reported intrusion-detection metrics must be interpreted in light of dataset hygiene (duplicates and leakage), how the operating threshold was chosen, and the deployment base rate. Threshold-free metrics like ROC-AUC and balanced-test scores can look excellent while the deployed system is impractical — the base-rate fallacy is the decisive consideration in rare-event security detection.

Strengths of the proposed solution. It requires no labelled attacks, is conceptually simple and computationally light, and is genuinely effective against high-deviation volumetric attacks — a reasonable first-line triage signal.

Weaknesses. It is blind to behaviourally-normal attacks; its reported performance is inflated by leakage and prevalence-blind reporting; and its published operating point is not robust to realistic deployment conditions.

Suggestions for future improvement. De-duplicate before splitting; always select thresholds on held-out data; report prevalence-aware precision; enrich the feature set with behavioural and temporal aggregates (per-source fan-out, beaconing regularity, packet-size entropy) to target stealthy attacks; and consider an ensemble combining the autoencoder with a complementary detector to cover both volumetric and low-volume attack regimes.

7. Executive Summary

This project critically reproduces Intrusion Detection System by GitHub user brett-gt, an autoencoder-based network intrusion detector evaluated on CIC-IDS2017. The source trains a sparse autoencoder on benign traffic only and flags flows by reconstruction error, reporting 98.3% attack detection at an 8.7% false-positive rate.

We reproduced the approach and audited its evidence. The autoencoder concept is valid — our leakage-free implementation achieves ROC-AUC 0.895 and MCC 0.738, and a comparable Isolation Forest baseline (AUC 0.868) confirms the result is not architecture-specific. But the source's specific claims overstate deployable performance for three reasons. First, CIC-IDS2017 contains 22.8% exact-duplicate records (concentrated in the attack class), and the source applies no de-duplication, so duplicates leak between the data the model is tuned on and the data it is evaluated on; the source's benign evaluation count (2,273,097) confirms the full duplicate-laden population is used. Second, the source selects its decision threshold directly on the test data. Third, the source reports only prevalence-independent rates; projected to realistic attack base rates, precision collapses to ~16% at 1% prevalence and ~2% at 0.1%.

Our error analysis shows the detector excels at volumetric attacks (DDoS, PortScan, DoS) but systematically misses stealthy, low-volume attacks (Bot, Infiltration) whose flow statistics resemble benign traffic — the missed attacks have reconstruction error indistinguishable from normal flows. We also identify reproducibility gaps: the exact feature subset, test-set composition, and dependency versions are underspecified.

We conclude that the autoencoder is a sound triage signal but not, as implied, a near-production-ready detector. The methodology is appropriate in concept, but its evaluation is not rigorous enough to support the headline numbers; corrected evaluation tells a more sobering — and more honest — story.

8. Summing It Up

- The problem: detecting malicious network traffic in flow-level data, framed as benign-only anomaly detection so that no labelled attacks are required.
- The selected source: Intrusion Detection System by GitHub user brett-gt — a sparse autoencoder scored by reconstruction error.
- The dataset: CIC-IDS2017 (~2.8M labelled flows, 83 statistical features; benign Monday, attacks Tuesday–Friday).
- The methodology: train an autoencoder on benign flows and threshold the per-flow reconstruction error. Our reproduction added de-duplication, benign-fitted standardisation, validation-based thresholding, a second model (Isolation Forest), and prevalence-aware metrics.
- Main findings: the approach is genuinely discriminative (AUC 0.895, MCC 0.738), but the source's 98.3%/8.7% claims are inflated by 22.8% duplicate leakage, a test-tuned threshold, and prevalence-blind reporting; at realistic prevalence, precision collapses.
- Whether the author's claims were supported: partially — the qualitative claim holds; the quantitative claims do not survive a leakage-free, prevalence-aware evaluation.
- Most important insights: de-duplication, held-out threshold selection, and base-rate-aware precision are decisive for honest intrusion-detection evaluation; and reconstruction-error detectors are blind to attacks that behave like normal traffic.
- Recommendation: usable as a lightweight, label-free triage component paired with prevalence-aware thresholds and complementary detectors; not as a standalone production detector at face-value performance.
- Final conclusion: the source's method is sound but its evidence is over-optimistic; corrected evaluation shows moderate, honest performance and a clear blind spot for stealthy attacks.